

PDPGuard

Automated Grey Box Penetration Testing and Data
Privacy Compliance Evaluation Platform

Present by Kelompok 14

Kelompok 14



Sofiyanatul Munawaroh



Timotius Kristafael
Harjanto



Roland Fernando



Abdul Mukhit Murtadho

Apa itu
PDPGuard?

Mengapa PDPPGuard Perlu Ada?

10

kategori kerentanan

API paling kritis menurut OWASP API Security
Top 10 2023 — BOLA, Broken Auth,
Misconfiguration, dan lainnya

Sumber: OWASP Foundation, 2023

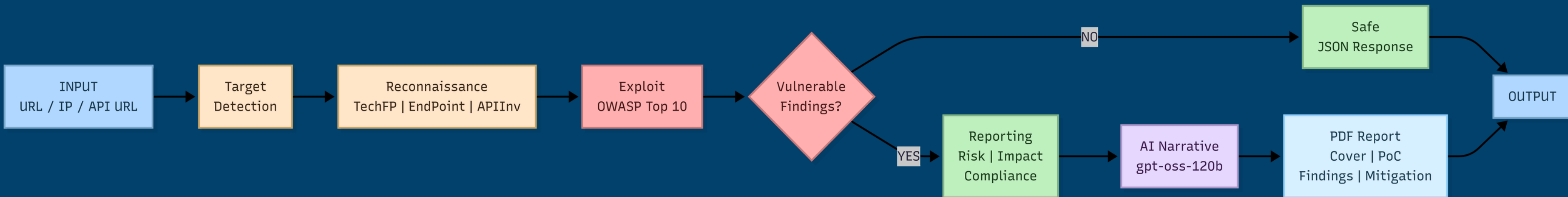
2%

dari pendapatan tahunan

Potensi denda administratif bagi organisasi
yang gagal menjaga keamanan data pribadi
pengguna

Sumber: UU No. 27 Tahun 2022

Bagaimana PDPGuard Bekerja?



Kebutuhan & Topologi Sistem

PDPGuard — Scanner

OS	Windows 11 64-bit
Python	3.11+ / venv
Backend	Flask + Flask-SQLAlchemy
HTTP Scan	requests + retry adapter
PDF	ReportLab
LLM	OpenAI SDK → OpenRouter
Database	PostgreSQL via psycopg2
Runtime	Localhost

Target App — PT. Dana Sejahtera

OS	Ubuntu 22.04 LTS
Docker Engine	v29.5.2
Docker Compose	v3.8
Backend	Go 1.23 · Gin · GORM · JWT
Frontend	Next.js 14 · TypeScript · Tailwind
Database	PostgreSQL 15
Testing	Jest · Playwright E2E
Runtime	Localhost (container)
Reverse Proxy	nginx

PDPGuard

Windows 11 · Flask · localhost

→ HTTP request →

← JSON response ←

PT. Dana Sejahtera

Ubuntu · Docker · port 80

Metodologi Pengujian

Fase	Deskripsi	Komponen PDPGuard
Identify	Mengidentifikasi target dan mengumpulkan informasi awal	Input Layer + Target Detection
Protect	Rekomendasi kontrol keamanan untuk melindungi sistem dari ancaman yang teridentifikasi	Rekomendasi output (PDF Report)
Detect	Reconnaissance dan eksploitasi aktif untuk mendeteksi kerentanan pada target	Reconnaissance + Exploit Phase
Respond	Pelaporan terstruktur yang diperkaya narasi AI untuk pemangku kepentingan teknis maupun non-teknis	Reporting + AI Narrative
Recover	Rekomendasi perbaikan jangka pendek dan panjang untuk memulihkan postur keamanan sistem	Rekomendasi di PDF Report

Standar Referensi

OWASP API Security Top 10 2023

NIST Cybersecurity Framework

Pendekatan Pengujian

Grey Box Penetration Testing

Automated Scanning

Target Pengujian PT. Dana Sejahtera

PT. Dana Sejahtera

Aplikasi web fintech manajemen pinjaman yang dibangun sebagai target uji penetrasi untuk mengevaluasi kemampuan scanner PDPGuard mendeteksi kerentanan API.

Fitur yang disimulasikan:

- Pendaftaran nasabah (NIK, alamat, telepon)
- Pengajuan pinjaman (jumlah, tenor, bunga)
- Persetujuan / penolakan oleh staf & admin
- Manajemen transaksi & riwayat pinjaman
- Administrasi pengguna & manajemen peran

Setiap kerentanan dipetakan ke pasal UU No. 27 Tahun 2022 (UU PDP).

Sistem Mode Ganda

MODE AMAN

- bcrypt + JWT 15 menit
- Account lockout (5x gagal)
- Rate limit 30 req/menit
- OWASP security headers

MODE RENTAN

- Plain-text password compare
- Token tanpa expiry (100 thn)
- Tidak ada rate limit / lockout
- v0 routes aktif & debug headers

Akun Default

Username	Password	Role
admin	Admin@123	admin
staff01	Admin@123	staff
budi_santoso	Admin@Dana2025!	admin
dewi_rahayu	Staff@Dana2025!	staff

* Role nasabah: daftar sendiri via POST /api/v1/auth/register

Target Pengujian PT. Dana Sejahtera

Arsitektur

CLIENT / SCANNER

Browser / PDPGuard

HTTP Port 80 ↓

NGINX

Reverse Proxy · Port 80

/api/* ↓ /* ↓

BACKEND Go/Gin

Port 8080 · JWT · GORM

SQL/GORM ↓

FRONTEND Next.js

Port 3000 · TypeScript

↓

DATABASE PostgreSQL

Port 5432 · v15

Tech Stack

Layer	Teknologi	Fungsi
Reverse Proxy	Nginx Alpine	Routing & single entry point
Backend	Go 1.23 + Gin	HTTP API & business logic
ORM	GORM v2	Abstraksi & auto-migrate
Auth	JWT golang-jwt/v5	Token autentikasi
Enkripsi	bcrypt (cost 10)	Password hashing aman
Logging	Zap – Uber	Structured logging
Frontend	Next.js 14 + TypeScript	App Router & SSR
Styling	Tailwind CSS v3	Utility-first CSS
Database	PostgreSQL 15	Relational & ACID
Container	Docker + Compose	Isolasi & orkestrasi

Deployment

Startup Order:

- PostgreSQL → pg_isready OK
- Backend Go → /health: 200 OK
- Frontend → service healthy
- Nginx → port 80 terbuka

Port Terekspos:

Port 80 → Nginx (satu entry point)
Port lain → internal Docker only

Mode Switching:

PUT /api/system/mode

```
{"mode": "vulnerable"}
```

```
{"mode": "secure"}
```

Auto-Deploy (Ubuntu VM):

- git fetch tiap 30 detik
- Auto rebuild jika ada commit

Konfigurasi .env:

APP_SECURITY_MODE=secure
JWT_SECRET=<min 32 chars>
DB_USER / DB_PASSWORD / DB_NAME

Middleware:

RequestLogger

ErrorHandler

CORS

SecureHeaders

RequestSizeLimit

GlobalRateLimit

AuthRequired

Handler

Target Pengujian PT. Dana Sejahtera

10 kerentanan OWASP API Security Top 10 (2023) – dipetakan ke UU PDP No. 27/2022

API1

HIGH

BOLA

GET /api/v1/nasabah tanpa filter kepemilikan — ekspos NIK semua nasabah

UU PDP: Pasal 39(1) jo. Pasal 38

API2

CRITICAL

Broken Auth

Plain-text compare, token 100 thn, /api/v0/users aksesibel tanpa auth

UU PDP: Pasal 35 jo. Pasal 39(2)

API3

HIGH

BOPLA

Nasabah B dapat PUT profil nasabah A; nasabah dapat approve pinjaman sendiri

UU PDP: Pasal 38 jo. Pasal 16(2)e

API4

HIGH

Resource Consumption

Tidak ada rate limit; pinjaman pending tidak dibatasi (flooding)

UU PDP: Pasal 35 huruf a

API5

HIGH

Function Level Auth

Token nasabah dapat akses /api/v1/admin/users dan ubah role pengguna

UU PDP: Pasal 38 jo. Pasal 39(1)

API6

HIGH

Business Flow

POST /api/v0/loans tanpa auth & tanpa batas jumlah pinjaman

UU PDP: Pasal 38 jo. Pasal 16(2)e

API7

HIGH

SSRF

POST /internal/fetch dengan url=http://169.254.169.254/meta-data

UU PDP: Pasal 35 jo. Pasal 38

API8

MEDIUM

Misconfiguration

7 security header absen; /api/v0/debug ekspos env vars & stack trace

UU PDP: Pasal 35 huruf a dan b

API9

MEDIUM

Inventory

/api/v0/users, /loans, /debug aktif dalam mode rentan (deprecated routes)

UU PDP: Pasal 39(1) jo. Pasal 16(2)e

API10

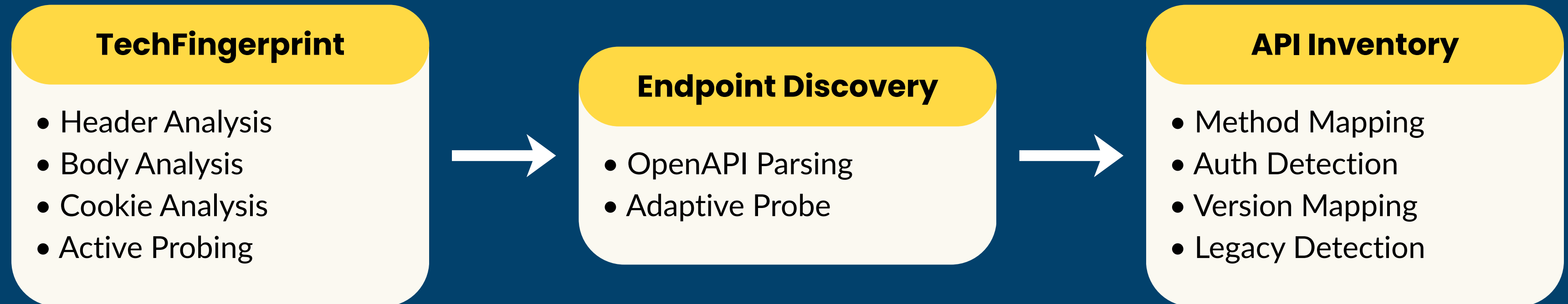
MEDIUM

Unsafe API

Fetch URL dari user tanpa allowlist; response tidak disanitasi

UU PDP: Pasal 37 jo. Pasal 38

Reconnaissance Engine



OWASP API Top 10 Testing Engine

API1 BOLA

API2 Auth

API3 BOPLA

API4 URC

API5 BFLA

API6 UABF

API7 SSRF

API8 MISCFG

API9 INV

API10 UAC

Compliance & **AI Reporting** Engine

1 Vulnerability Detection (Exploit Module)

2 Risk Engine | risk.py | Severity & Score

3 PDP Compliance | compliance.py
| Pasal & Sanksi

4 Business Impact | impact.py
| Financial & Rep

5 Recommendation | recommendation
| Mitigation

6 report.py | Generate JSON
| Security Report

7 pdf_generator | Generate PDF
| Final Report

Demo Scan — Hasil Reconnaissance

41

Endpoint ditemukan

5

Framework terdeteksi

3

Path exposed (HTTP 200)

Tech Stack Terdeteksi

Go/Gin — Server header
Next.js — X-Powered-By
Nginx — Server header
Express.js — X-Powered-By
Micronaut — Pattern match

Response Headers

Server nginx/1.31.1
TLS/HTTPS Tidak aktif
Auth Type Unknown
X-Powered-By Next.js

Active Paths Exposed

/admin/ HTTP 200
/admin/login/ HTTP 200
/health HTTP 200

Demo Scan — Hasil Exploit Phase

1

CRITICAL

6

HIGH

3

MEDIUM

0

LOW

OWASP ID	KERENTANAN	SEVERITY	EVIDENCE SINGKAT
API2	Broken Authentication	CRITICAL	Endpoint /api/v0/users dapat diakses dengan token null/malformed/alg:none
API1	Broken Object Level Auth (BOLA)	HIGH	GET /api/v1/nasabah mengembalikan semua record tanpa filter kepemilikan
API3	Broken Object Property Level Auth	HIGH	Cross-user write berhasil — ownership check dapat di-bypass
API4	Unrestricted Resource Consumption	HIGH	50 request dalam 1 detik tidak ada rate limiting sama sekali
API5	Broken Function Level Auth	HIGH	Akses ke /api/v1/admin/users tanpa autentikasi — credential hash bocor
API6	Unrestricted Business Flow	HIGH	5/5 pengajuan pinjaman berhasil tanpa batasan pending-loan
API7	Server Side Request Forgery (SSRF)	HIGH	POST /api/v1/internal/fetch merefleksikan SSRF signal ke localhost
API8	Security Misconfiguration	MEDIUM	Security headers hilang, CORS wildcard (*) aktif
API9	Improper Inventory Management	MEDIUM	/health endpoint production merespons HTTP 200 tanpa restriksi
API10	Unsafe Consumption of APIs	MEDIUM	Server memfetch URL eksternal tidak terpercaya via blind proxy

Implikasi **Regulasi** — Mapping ke **UU PDP**

KERENTANAN	PASAL UU PDP YANG DILANGGAR	COMPLIANCE SCORE
Broken Authentication	Pasal 35 jo. Pasal 39 ayat (2)	0/100
Broken Object Level Auth (BOLA)	Pasal 39 ayat (1) jo. Pasal 38	20/100
Broken Object Property Level Auth	Pasal 38 jo. Pasal 16 ayat (2) huruf e	20/100
Unrestricted Resource Consumption	Pasal 35 ayat (a)	20/100
Broken Function Level Auth	Pasal 38 jo. Pasal 39 ayat (1)	20/100
Unrestricted Business Flow	Pasal 38 jo. Pasal 16 ayat (2) huruf e	20/100
Server Side Request Forgery (SSRF)	Pasal 35 jo. Pasal 38	20/100
Security Misconfiguration	Pasal 35 huruf a dan huruf b	50/100
Improper Inventory Management	Pasal 39 ayat (1) jo. Pasal 16 ayat (2) huruf e	50/100
Unsafe Consumption of APIs	Pasal 37 jo. Pasal 38	50/100

2%

Sanksi administratif — denda hingga 2% dari pendapatan tahunan (Pasal 57)

Sanksi pidana — penjara maks. 5 tahun dan/atau denda maks. Rp5.000.000.000 (Pasal 67 ayat 3)

Evaluasi **Performa** PDGuard

| PRECISION & RECALL DETEKSI

83.3%

Precision
Kedua mode pengujian

100%

Recall
Kedua mode pengujian

2

False Positive
Celah Residual API4 & API9

80%

Specificity
Pada Mode Aman

| Coverage Modul OWASP — 10/10 (100%)

API1 — BOLA

✓ Aman

✓ Rentan

API3 — Property Auth

✓ Aman

✓ Rentan

API5 — Function Auth

✓ Aman

✓ Rentan

API7 — SSRF

✓ Aman

✓ Rentan

API9 — Inventory

⚠ Aman

✓ Rentan

API2 — Broken Auth

✓ Aman

✓ Rentan

API4 — Resource Consumption

⚠ Aman

✓ Rentan

API6 — Business Flow

✓ Aman

✓ Rentan

API8 — Misconfiguration

✓ Aman

✓ Rentan

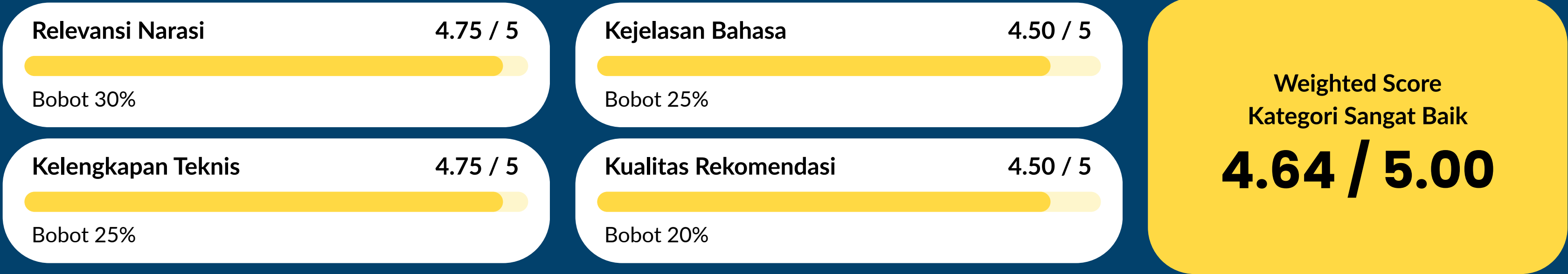
API10 — Unsafe API

✓ Aman

✓ Rentan

Evaluasi **Performa** PDPGuard

| Kualitas AI Narrative — Human Evaluation (n=12)



| Performa Teknis

Parameter	Mode Aman	Mode Rentan
Total waktu scan	~130 detik	~140 detik
Endpoint terdeteksi	38	41
Temuan dilaporkan	2	10
Ukuran file PDF	28 KB	57.5 KB

Rekomendasi **Keamanan**

Jangka Pendek

- Implementasi MFA dan validasi token yang ketat (API2)
- Tambahkan object-level access control + RBAC/ABAC (API1, API3, API5)
- Aktifkan rate limiting dan throttling per user/IP (API4)
- Konfigurasi security headers dan hapus CORS wildcard (API8)
- Validasi dan sanitasi semua URL input — blokir IP privat (API7)

Jangka Panjang

- Terapkan state-machine workflow untuk business flow kritis (API6)
- Bangun inventaris API terpusat dan nonaktifkan endpoint deprecated (API9)
- Terapkan allow-list ketat untuk konsumsi API eksternal (API10)
- Lakukan compliance assessment berkala terhadap UU PDP
- Integrasikan PDPGuard ke dalam CI/CD pipeline sebagai automated security gate

Kesimpulan

01

PDPGuard berhasil mendeteksi **10 kerentanan API secara otomatis** pada simulasi aplikasi fintech PT. Dana Sejahtera — mencakup seluruh kategori OWASP API Top 10 2023

02

Setiap temuan **dipetakan langsung ke pasal-pasal UU PDP** beserta skor kepatuhan dan potensi sanksi — menjadikan laporan siap pakai untuk compliance assessment

03

Pipeline berjalan **end-to-end secara otomatis** — dari reconnaissance, exploit, reporting, hingga laporan PDF bernarasi AI tanpa intervensi manual

04

PDPGuard membuktikan bahwa audit keamanan API bisa dilakukan secara **lebih cepat, terstruktur, dan compliance-aware** dibanding pendekatan manual konvensional

THANK YOU